Lab 3A: Phishing Simulation and Quantitative Risk Analysis

GlobalTech Inc.

Name: Madubuonu Chisom Anthonia
Date: 30 October 2026

This report has the calculations for the three phishing campaigns, the risk matrix, the confidence interval, the executive briefing and the bonus question. The tables from my Excel workbook are in the appendix at the end.

GlobalTech has 2,000 employees. One data breach costs $4,350,000, and the lab uses a 25% chance of a major breach whenever credentials are stolen. Campaign A went to 100 employees, Campaign B to 250 and Campaign C to 80.

1. Calculation worksheets

Phase 1, Step 1: Basic rates

Each rate is the number of events divided by the number of emails sent.

Campaign	Open rate	Click-through rate	Credential submission rate	Data entry rate
A	82/100 = 82%	47/100 = 47%	18/100 = 18%	5/100 = 5%
B	200/250 = 80%	150/250 = 60%	75/250 = 30%	25/250 = 10%
C	72/80 = 90%	60/80 = 75%	12/80 = 15%	8/80 = 10%

Phase 1, Step 2: Efficiency

Campaign	Open to click	Post-click credential submission
A	47/82 = 57.3%	18/47 = 38.3%
B	150/200 = 75%	75/150 = 50%
C	60/72 = 83.3%	12/60 = 20%

Campaign B did the most damage. Half of the people who clicked the link (75 out of 150) went on to enter their credentials. In Campaign C more of the people who opened the email clicked (83.3%), but only 20% of those who clicked gave up their credentials, so the executives were more careful at that last step.

Phase 2, Step 3: Exposure for Campaign B

Employees expected to give up credentials: 2,000 × (75/250) = 2,000 × 0.30 = 600.

Expected data breaches: 600 × 25% = 150.

Phase 2, Step 4: Financial impact

Total financial exposure: 150 × $4,350,000 = $652,500,000.

ALE = SLE × ARO = $4,350,000 × 150 = $652,500,000.

Phase 2, Step 5: Controls

Control	Cost	Risk reduction	Net benefit	ROI
MFA	$90,000	$651,847,500	$651,757,500	724,175%
Security training	$100,000	$391,500,000	$391,400,000	391,400%

MFA: the cost is $45 × 2,000 employees = $90,000. It blocks 99.9% of the risk, so the reduction is $652,500,000 × 0.999 = $651,847,500. ROI = ($651,847,500 - $90,000) / $90,000 = 7,241.75, which is 724,175%.

Training: the cost is $50 × 2,000 = $100,000. A 60% drop in the 30% rate gives a new rate of 30% × 0.40 = 12%. That means 2,000 × 0.12 = 240 employees, 240 × 0.25 = 60 breaches, and a new ALE of 60 × $4,350,000 = $261,000,000. The reduction is $652,500,000 - $261,000,000 = $391,500,000, and ROI = ($391,500,000 - $100,000) / $100,000 = 391,400%.

2. Risk assessment matrix

Campaign	Calculation	Financial exposure	Priority	Risk level	Recommended action
A	(18/100) × 2,000 = 360 employees × 0.25 × $4,350,000	$156,600,000	2	MEDIUM-HIGH	Enhanced Training
B	(75/250) × 2,000 = 600 employees; 600 × 0.25 = 150 breaches × $4,350,000	$652,500,000	1	CRITICAL	IMMEDIATE MFA
C	(12/80) × 2,000 = 300 employees × 0.25 × $4,350,000	$104,400,000	2	HIGH	Executive Training

Campaign B has by far the highest exposure, so MFA comes first. Campaigns A and C share second priority.

3. Statistical analysis

I used the 95% confidence interval for a proportion: $p \pm 1.96 \times \sqrt{(p(1 - p) / n)}$.

Campaign	p	n	Margin of error	Likely range
A	0.18	100	$1.96 \times \sqrt{(0.18 \times 0.82 / 100)} = 0.0753$	10.5% to 25.5%
B	0.30	250	$1.96 \times \sqrt{(0.30 \times 0.70 / 250)} = 0.0568$	24.3% to 35.7%

Only 100 employees received Campaign A, so its range is wide. The true credential rate could be anywhere from about 10% to 26%. Campaign B went to 250 people, which gives a tighter range.

Even the bottom of B's range (24.3%) is higher than the 18% seen in A, so B really does look like the more successful campaign and the difference is probably not luck.

4. Executive briefing

To: Board of Directors, CISO, CFO
From: GRC Risk Analysis Team
Date: 30 October 2026
Subject: CRITICAL: Quantitative Phishing Risk Assessment & $652M Exposure

Summary

Our phishing simulation shows a critical risk exposure of $652 million a year. The "IT System Password Reset" campaign had a 30% credential submission rate, which works out to about 600 compromised accounts across 2,000 employees. We recommend rolling out multi-factor authentication to everyone straight away.

Key figures

Risk metric	Value	Industry average	Severity
Overall credential theft rate	22.1%	15.3%	HIGH
Maximum campaign success rate	30%	18.7%	CRITICAL
Annualized loss expectancy	$652M	$285M	SEVERE
MFA implementation ROI	724,175%	350%	EXCELLENT

Current state: annualized loss expectancy of $652,500,000, a 93.75% probability of a major breach (150 expected breaches) and a risk of $326,250 per employee.

Control recommendations

Control	Cost	Risk reduction	Net benefit	ROI	Priority
MFA implementation	$90,000	$651.8M	$651.7M	724,175%	1
Enhanced training	$100,000	$391.5M	$391.4M	391,400%	2
Email filtering	$50,000	$130.5M	$130.4M	260,800%	3

Recommended actions

In the first quarter: enterprise-wide MFA ($90,000), a targeted phishing simulation program ($25,000) and emergency security awareness training ($100,000).

Over the next 12 months: an advanced email security gateway ($50,000), continuous security monitoring ($150,000) and security behavior analytics ($75,000).

Expected results

Metric	Current	With controls	Reduction
Credential theft rate	22.1%	2.2%	90%
Annual loss expectancy	$652M	$65M	90%
Breach probability	93.75%	25%	73.3%

Total investment required: $490,000. Total risk reduction: $587,500,000. Net financial benefit: $587,010,000.

5. Bonus: break-even point

Break-even = $490,000 / $4,350,000 per breach = 0.11 breaches. The investment pays for itself if it stops roughly one ninth of a single breach, and stopping one whole breach would return it about nine times over.

6. Limits of this analysis

The model treats every stolen credential as its own 25% chance of a full $4,350,000 breach. That is why the exposure figure is so large. In real life one breach event is more likely than 150 separate ones, so the true exposure is probably lower.

The samples are small (100 emails for Campaign A and 80 for Campaign C), which is why the confidence interval for A is so wide. The control effects (MFA at 99.9%, training at 60%, email filtering at 20%) are assumptions rather than measured results, and the controls overlap, so their benefits should not be added up blindly. MFA can also still be bypassed, for example by repeatedly pushing approval requests until a user gives in. Finally, a simulated phishing test may not match how a real attacker behaves. The industry averages and the breach probability figure are as given in the lab.

Appendix: Excel worksheets

These are the tables from my Excel workbook. The workbook itself has the formulas.

Data

Campaign	Sent	Opened	Clicked	Creds	DataEntry
A	100	82	47	18	5
B	250	200	150	75	25
C	80	72	60	12	8

Rates

Campaign	Open	Click	Creds	Data entry	Open to click	Post-click creds
A	82.0%	47.0%	18.0%	5.0%	57.3%	38.3%
B	80.0%	60.0%	30.0%	10.0%	75.0%	50.0%
C	90.0%	75.0%	15.0%	10.0%	83.3%	20.0%

Risk

Campaign	Credential rate	Employees compromised	Financial exposure	Priority	Risk level
A	18.0%	360	$156,600,000	2	MEDIUM-HIGH
B	30.0%	600	$652,500,000	1	CRITICAL
C	15.0%	300	$104,400,000	2	HIGH

Controls

Item	MFA	Training	Email filtering
Cost	$90,000	$100,000	$50,000
New credential rate	n/a	12%	n/a
New credentials stolen	n/a	240	n/a
New expected breaches	n/a	60	n/a
New ALE	n/a	$261,000,000	n/a
Risk reduction	$651,847,500	$391,500,000	$130,500,000
ROI	724,175%	391,400%	260,800%